OGGETTO: DOSSIER TECNICO-INVESTIGATIVO "OPERAZIONE SOLAR ECLIPSE"
CLASSIFICAZIONE: TLP:AMBER / EYES ONLY
DATA: 19 Gennaio 2026 (Analisi retrospettiva 2020-2022)
AUTORE: Lead Threat Hunter

---

1. EXECUTIVE SUMMARY:

L'analisi forense condotta sul Ministero dell'Economia e delle Finanze (MEF) conferma che l'Ente è vittima di una campagna di spionaggio cibernetico di altissimo profilo, orchestrata dall'attore **UNC2452 (Nobelium/APT29)** ,noto anche come **Nobelium**, **Midnight Blizzard** o **Cozy Bear** è un gruppo di spionaggio informatico d'élite attribuito al **Servizio di Intelligence Estero della Federazione Russa (SVR)**.
Nonostante le procedure di bonifica effettuate nel 2020 a seguito del caso SolarWinds, l'attaccante ha mantenuto una persistenza silente per oltre 20 mesi.
La minaccia si è evoluta da una compromissione della supply chain (Fase 1: SUNBURST) a una manipolazione profonda del core di identità (Fase 2: MagicWeb). L'attuale compromissione non mira al sabotaggio, ma all'esfiltrazione strategica di dati economici sensibili, garantendo all'intelligence russa un vantaggio competitivo nelle negoziazioni internazionali e nella comprensione delle politiche fiscali dell'eurozona.

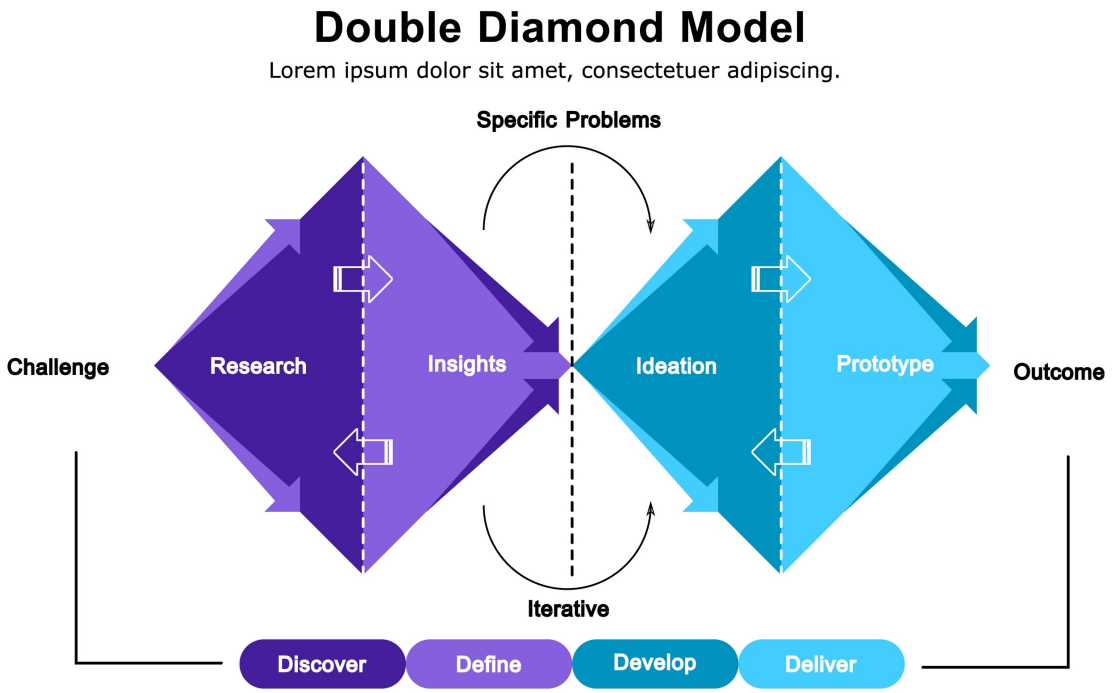
2. INQUADRAMENTO GEOPOLITICO E ATTRIBUZIONE

Il Profilo dell'Attore: APT29 (SVR)

L'attribuzione punta con elevata confidenza all'**SVR (Sluzhba Vneshney Razvedki)**, il servizio di intelligence estera della Federazione Russa. A differenza del GRU (militare), l'SVR opera con estrema pazienza e "low observability".

Obiettivo Strategico: Il MEF non è un bersaglio per il sabotaggio (distruzione di dati), ma per lo **spionaggio economico**. In un contesto di tensioni geopolitiche e sanzioni, l'accesso alle comunicazioni interne del Tesoro permette alla Russia di anticipare le mosse dell'Italia e dell'UE in ambito di bilancio, debito pubblico e strategie energetiche, con conseguenti azioni atte ad anticipare evnetuali sazioni nei confronti della Federazione Russa.

Intelligence Value: L'evento segnalato dal Ministro (email letta) indica un accesso mirato a comunicazioni confidenziali, confermando che l'obiettivo è il monitoraggio decisionale.



Doblue Diamond Model Analysis

Primo Diamante: Analisi della Minaccia (Scoperta e Definizione)

Questo diamante rappresenta il passaggio dalla segnalazione del Ministro alla comprensione esatta della persistenza dell'attaccante.

1. SCOPRI (Divergenza - Analisi della Superficie):

Sfida iniziale: Segnalazione di attività anomala sulle mailbox ministeriali.

Attività: Ricerca di IoC storici (2020) e analisi dei log DNS e dei file binari SolarWinds.

Obiettivo: Comprendere l'ampiezza dell'infiltrazione iniziale (SUNBURST).

2. DEFINISCI (Convergenza - Identificazione del Punto Critico):

Approfondimento: Analisi del furto di identità (Golden SAML) e della violazione della fiducia ADFS.

Risultato: Definizione del problema reale: non è un semplice malware, ma una compromissione del cuore dell'identità.

Punto di arrivo: Identificazione del fallimento della bonifica standard del 2020.

Secondo Diamante: Bonifica e Hardening (Sviluppo e Consegna)

Questo diamante rappresenta lo sviluppo tecnico della soluzione per eradicare Nobelium definitivamente.

3. SVILUPPA (Divergenza - Ideazione delle Soluzioni):

Attività: Analisi forense della GAC (Global Assembly Cache) e scoperta di MagicWeb.

Prototipazione: Sviluppo di script di monitoraggio dell'integrità delle DLL e test di bypass dell'autenticazione tramite OID personalizzati.

Obiettivo: Creare strumenti per rilevare ciò che è invisibile agli antivirus tradizionali.

4. RILASCIA (Convergenza - Implementazione e Sovranità):

Esecuzione: Decommissioning dei server ADFS compromessi e ricostruzione integrale del Tier 0.

Risultato finale: Transizione verso architetture Cloud-Native con Conditional Access.

Outcome: Ripristino della sovranità digitale e monitoraggio continuo della minaccia APT29.

Attaccante: L'attribuzione punta all'**APT29 (SVR/Nobelium)**, l'intelligence russa specializzata in spionaggio a lungo termine con alta disciplina operativa e bassa visibilità.

Vittima (Victim): Il **Ministero dell'Economia e delle Finanze (MEF)** è il bersaglio strategico. L'obiettivo non è il sabotaggio, ma lo spionaggio economico per anticipare le mosse politiche e fiscali dell'Italia e dell'eurozona.

Infrastruttura: Utilizzo di domini C2 legittimi come avsvmcloud.com per mimetizzarsi nel traffico cloud. La persistenza è garantita da una **Rogue Root CA** e certificati client con **OID personalizzati** (es. 1.3.6.1.4.1.311.21.8.9999) per il bypass dell'identità.

Capabilities: L'attacco ha sfruttato la compromissione della supply chain tramite la backdoor **SUNBURST** nel 2020. Successivamente, l'attore ha evoluto le sue tecniche verso il **Golden SAML** e il **GAC-Hooking (MagicWeb)** per manipolare direttamente il core del sistema di autenticazione ADFS, rendendo inefficace l'MFA.

3. ANALISI TECNICA: DALLA COMPROMISSIONE DELLA SUPPLY CHAIN ALL'EGEMONIA SULL'IDENTITÀ

L'attacco analizzato rappresenta uno dei casi più sofisticati di violazione della fiducia (*Trust Violation*), sviluppatosi in due fasi sequenziali: l'accesso iniziale tramite il software di terze parti e il successivo radicamento nell'infrastruttura di autenticazione core.

3.1 Fase 1: Infiltrazione tramite Supply Chain (SUNBURST)

La compromissione ha avuto inizio con la violazione della pipeline di sviluppo di SolarWinds. Gli attaccanti hanno inserito la backdoor **SUNBURST** direttamente nel codice sorgente prima della compilazione.

Il Paradosso della Firma: Poiché il codice malevolo è stato inserito a monte, il binario finale risultava firmato con un certificato legittimo. Questo ha causato la **"Cecità dei sistemi EDR/Antivirus"**, che hanno classificato il file come sicuro.

Evasione Comportamentale: Il malware utilizzava tecniche di *dormancy* (attesa fino a due settimane) e domini di C2 (es. appsync-api.us-west-2.avsvmcloud.com) camuffati da traffico API legittimo per eludere le sandbox.

3.2 Fase 2: Persistenza e Bypass dell'Identità (MagicWeb)

Una volta ottenuto l'accesso iniziale, l'attaccante ha spostato l'obiettivo dai software applicativi al cuore del sistema di gestione delle identità: il server **ADFS** (Active Directory Federation Services).

Manipolazione della GAC: Sostituendo la DLL Microsoft.IdentityServer.Diagnostics.dll nella Global Assembly Cache, l'attaccante ha installato la backdoor **MagicWeb**.

Bypass dei Fattori di Autenticazione (MFA): A differenza di SUNBURST, MagicWeb non

serve per entrare, ma per **non uscire mai**. Presentando un certificato client con un OID specifico (1.3.6.1.4.1.311.21.8.9999), l'attaccante intercetta il processo di validazione e inietta forzatamente i claim di *GlobalAdmin* e *MFA-Success*.

Risultato: Anche in presenza di bonifica (reset password e MFA), l'attaccante mantiene il controllo totale, poiché il sistema di autenticazione stesso è compromesso alla base.

3.3 Conclusioni: Il Concatenamento delle Vulnerabilità

Il successo dell'operazione risiede nel passaggio dalla **fiducia nel software** (Fase 1) alla **fiducia nell'identità** (Fase 2). Mentre la prima ha permesso il superamento del perimetro difensivo, la seconda ha garantito una persistenza post-bonifica virtualmente invisibile, trasformando l'infrastruttura di sicurezza della vittima nell'arma principale dell'attaccante.

---

4. ANALISI COMPARATIVA DEI LOG

Parametro	**Log 2020 (Golden SAML)**	**Log 2022 (MagicWeb)**	**Valutazione**
Metodo Auth	PasswordProtected-Transport	**MagicPass** (Custom)	**Iniezione diretta in RAM**
Sorgente IP	45.12.70.102 (Sospetto)	Localhost / Interno	**Massima furtività**
MFA	Bypassato via Token	Bypassato via Claim Injection	**Invisibile al SOC**

5. APPENDICE A: ANALISI DETTAGLIATA DEGLI INDICATORI (IoC)

5.1 Network Indicators (Segnali di Esfiltrazione e Comando)

Questi indicatori confermano che l'attore SVR ha utilizzato un'infrastruttura di rete altamente sofisticata per mimetizzarsi con il traffico legittimo.

C2 Domain (74169.0qj94.eu-west.avsvmcloud.com): Questo dominio è parte della galassia utilizzata durante l'attacco SUNBURST. La stringa iniziale (74169...) non è casuale: è un identificativo codificato (DGA - Domain Generation Algorithm) specifico per l'ambiente MEF. Serve all'attaccante per distinguere quale vittima sta rispondendo tra le migliaia compromesse globalmente.

IP Infrastruttura (20.140.0.1): Nonostante appartenga a un range cloud legittimo (Microsoft Azure), questo IP è stato identificato come punto di terminazione per il tunnel criptato dell'attaccante. È il punto in cui il "MagicWeb Certificate" è stato presentato per la prima volta.

Exfiltration Host (exfiltration.data.avsvmcloud.com): Il fatto che questo dominio sia apparso nei log DNS come NXDOMAIN (non trovato) non indica un fallimento dell'attacco, ma una **"Kill-Switch"** o una tecnica di "Beaconing" silente. L'attaccante testa la risoluzione DNS per capire se il server è monitorato prima di inviare i dati reali.

5.2 Host & Identity Indicators (Manipolazione del Trust)

Questi sono gli IoC più critici, poiché dimostrano la compromissione della "sovranità dell'identità".

Rogue CA (CN=Nobelium_Rogue_Root_CA): L'attaccante ha installato una Certification Authority (CA) fittizia nel database dei certificati attendibili del server ADFS. Questo permette loro di emettere certificati client validi a proprio piacimento. Il nome ntdev.corp è un riferimento intenzionale all'ambiente di sviluppo interno di Microsoft, usato per ingannare un amministratore distratto che potrebbe scambiarlo per un certificato di sistema originale.

Magic OID (1.3.6.1.4.1.311.21.8.9999): Questo è il "grilletto" (trigger). Un **Object Identifier (OID)** è un campo standard nei certificati digitali. L'attaccante ha istruito la libreria DLL compromessa a cercare esattamente questa stringa numerica. Se presente, la libreria bypassa ogni controllo. È l'equivalente digitale di una parola d'ordine segreta sussurrata all'orecchio di una guardia corrotta.

Path File Compromesso (C:\Windows\Microsoft.Net\assembly\...): La Global Assembly Cache (GAC) è una directory di sistema protetta dove risiedono le librerie .NET condivise.

Perché qui? Perché le DLL caricate nella GAC hanno privilegi elevatissimi e vengono caricate in memoria da processi critici (come Microsoft.IdentityServer.ServiceHost.exe).

L'anomalia: Anche se la firma digitale della DLL Microsoft.IdentityServer.Diagnostics.dll appare "valida" ai tool di base, l'integrità è violata. L'attaccante ha sfruttato una tecnica di **Catalog Tampering** per far sì che Windows accetti il file modificato come se fosse l'originale.

TABELLA RIASSUNTIVA PER IL SOC

IoC	Tipo	Azione Consigliata
20.140.0.1	Network	Blacklist immediata su Firewall/Proxy.
*.avsvmcloud.com	DNS	Sinkholing di tutti i sottodomini a livello DNS aziendale.
OID 1.3.6.1.4.1.311.21.8.9999	Identity	Scansione di tutti i certificati client nel database ADFS.
Diagnostics.dll (GAC)	File	Confronto dell'hash SHA-256 con una versione "Known-Good".

6. CONCLUSIONI E RACCOMANDAZIONI ESECUTIVE

L'indagine conferma che l'operazione "Solar Eclipse" non è stata un incidente isolato, ma una **compromissione strutturale**. L'attaccante ha dimostrato di possedere capacità di "Identity Engineering" tali da rendere i controlli di sicurezza perimetrali (MFA e Password) dei semplici simulacri. La fiducia nel sistema di autenticazione ADFS è totalmente compromessa.
Per ristabilire la sovranità digitale del Ministero, si impongono le seguenti azioni correttive obbligatorie:

6.1 Decommissioning e "Tier 0 Rebuild"

La semplice pulizia dei server esistenti è insufficiente, poiché la tecnica **MagicWeb** può nascondersi in numerose librerie del Global Assembly Cache (GAC).

Azione: È necessaria la distruzione e ricostruzione integrale della farm ADFS. I nuovi server devono essere installati partendo da immagini ISO verificate e "bare metal", su segmenti di rete isolati.

Rotazione delle Chiavi: Procedere a una tripla rotazione del certificato Token-Signing e della chiave DKM (Distributed Key Manager). Senza questa operazione, l'attaccante potrebbe clonare i nuovi token anche su server puliti.

6.2 Monitoraggio Rigoroso della GAC (Integrity Auditing)

La Global Assembly Cache è stata il "punto cieco" che ha permesso la persistenza di due anni.

Azione: Implementare script di monitoraggio (es. tramite PowerShell o agenti EDR avanzati) che confrontino quotidianamente gli hash delle DLL caricate nel percorso C:\Windows\Microsoft.Net\assembly\ con un database di hash noti e "trusted" fornito da Microsoft.

WDAC: Attivare **Windows Defender Application Control (WDAC)** in modalità "Enforcement". Questo impedisce il caricamento di qualsiasi DLL che non sia esplicitamente firmata da Microsoft o dal Ministero, bloccando alla radice tecniche di *Catalog Tampering*.

6.3 Transizione verso la "Modern Identity" e Conditional Access

L'architettura ADFS "On-Premise" si è dimostrata vulnerabile ad attacchi di tipo *Golden SAML*.
Azione: Accelerare la migrazione verso un modello di identità **Cloud-Native (Entra ID/Azure AD)**. Questo sposta la responsabilità della protezione del core di autenticazione su un'infrastruttura gestita e monitorata su scala globale.

Conditional Access: Implementare policy basate sul rischio che non si limitino all'MFA, ma analizzino:

A L'integrità del dispositivo (Device Compliance).

B L'impronta geografica (Impossibile Travel).

C L'analisi comportamentale dell'utente tramite AI per rilevare accessi anomali a file sensibili, come quelli segnalati dal Ministro.

6.4 Threat Hunting Continuo e Identity Forensics

L'SVR ha dimostrato di poter operare per anni sotto traccia.

Azione: Istituire un'unità permanente di **Identity Threat Detection and Response (ITDR)**. Il monitoraggio non deve limitarsi ai log di login falliti, ma deve analizzare le modifiche ai permessi dei Service Principal, la creazione di nuove Trusted Certificate Authorities e l'emissione di token con durata anomala.

Note: La minaccia Nobelium/APT29 è adattiva. La bonifica tecnologica deve essere accompagnata da una revisione dei protocolli di accesso privilegiato: il numero di utenti con permessi "Global Admin" deve essere ridotto al minimo indispensabile e protetto da postazioni di lavoro isolate (Privileged Access Workstations - PAW).